PROTEXXA CYBER NATIONS SCOTIARISE CYBER SECURITY ANALYST PROGRAM
ASSIGNMENT 5: RISK ASSESMENT

RISK ASSESMENT

EQUIFAX

2017 DATA BREACH RISK ASSESSMENT ANALYSIS



LEAD RISK ASSESSOR: ZOLIAN SMITH
ORGANIZATION: EQUIFAX INC.
ASSESSMENT PERIOD: OCTOBER 1, 2017 - OCTOBER 30, 2017
REPORT DATE: OCTOBER 31, 2017

Zolian R. Smith
August 10, 2025

Introduction & Company Overview

The purpose of this report is to present the findings of a risk assessment exercise carried out from **October 1, 2017** to **October 30, 2017** with the scope described below. The main purpose of the exercise was to assess the risks to **Equifax Inc.** following the major cybersecurity incident that occurred between May and July 2017, and to identify which of these risks could be accepted and which require immediate action to address them.

Equifax Inc. is one of the three largest credit reporting agencies in the United States, providing credit monitoring and identity protection services to consumers and businesses. The company maintains credit information on over 800 million consumers and more than 88 million businesses worldwide. With headquarters in Atlanta, Georgia, Equifax operates across 24 countries and employs approximately 11,000 people globally.

In September 2017, Equifax disclosed that it had experienced a massive cybersecurity breach that occurred between **May 13, 2017, and July 30, 2017**. The breach exploited a vulnerability in Apache Struts (CVE-2017-5638) that had been publicly disclosed and patched in March 2017, but Equifax failed to implement the security update. This incident compromised the personal information of **147.9 million Americans**, **15.2 million British citizens**, and approximately **19,000 Canadian citizens**, making it one of the largest cybercrimes related to identity theft in history.

The compromised information included names, Social Security numbers, birth dates, addresses, driver's license numbers, and credit card numbers for approximately 209,000 consumers. The financial impact has been severe, with Equifax agreeing to a settlement of up to **$1.38 billion**, including **$425 million** for consumer compensation and a **$100 million** civil fine.

Upon approval of this risk assessment report, specific actions and mitigation strategies will be identified, discussed, and agreed upon. These actions will then be documented in a risk treatment plan, forming part of the organization's **Information Security Management System (ISMS)**. This will ensure a structured and proactive approach to managing risks.

The process followed for this risk assessment is outlined in the **Risk Assessment and Treatment Process** document, which is part of the ISMS and provides the framework for evaluating and addressing identified risks. This risk assessment report describes:

- The context and scope of the risk assessment
- The assets within scope
- Threats to, and vulnerabilities of, those assets

This report is input to the risk treatment stage of the process and must be signed off by top management before continuing further. This risk assessment was carried out by the following people:

NAME	ROLE IN ASSESSMENT
Zolian Smith	Lead Risk Assessor

Table 1: Risk assessment team

As part of the assessment, the following additional people were consulted:

NAME	TITLE	LOCATION
Richard F. Smith	Chief Executive Officer	Atlanta office
Susan Mauldin	Chief Security Officer	Atlanta office
David Webb	Chief Technology Officer	Atlanta office

Table 2: People consulted

Risk Assessment Context & Objectives

This risk assessment was conducted in response to the major data breach incident that occurred at Equifax between May and July 2017. The assessment aims to:

1. Identifying and evaluating potential risks following the Apache Struts vulnerability exploitation.

2. Prioritizing risks according to their impact and likelihood on business operations and stakeholder trust.

3. Developing risk mitigation strategies to prevent similar incidents and restore confidence.

4. Providing recommendations to improve risk management processes and cybersecurity posture.

Internal and External Context

This risk assessment was carried out following the discovery and public disclosure of the massive data breach in September 2017. The breach has resulted in significant financial liability, regulatory scrutiny, loss of consumer trust, and potential legal implications. The assessment is critical for:

- Restoring stakeholder confidence
- Meeting regulatory compliance requirements
- Preventing future security incidents
- Establishing a robust cybersecurity framework

Scope

This assessment addresses the risks to Equifax's information systems and data assets following the 2017 cybersecurity incident. The scope includes:

- **Included:** All information systems containing consumer credit data, personally identifiable information (PII), financial records, and business-critical applications within Equifax's U.S. operations
- **Excluded:** International subsidiaries' independent systems, third-party vendor systems not directly integrated with Equifax infrastructure, and physical security risks unrelated to the cyber incident

The assessment focuses specifically on cybersecurity risks and their potential impact on business operations, regulatory compliance, and stakeholder trust.

Risk Assessment Methodolgy & Results Summary

This risk assessment employs a comprehensive approach combining multiple industry-standard methodologies:

Primary Methodologies:

- **ISO 27001** framework for information security management
- **NIST Cybersecurity Framework** for risk identification and management
- **Qualitative Risk Assessment** using expert judgment and stakeholder input
- **Risk Matrix Analysis** using likelihood versus impact evaluation

Assessment Process:

1. **Asset Identification**: Catalogued critical business assets affected by or potentially vulnerable to the security incident
2. **Threat Analysis**: Identified specific threats targeting each asset category
3. **Vulnerability Assessment**: Evaluated existing weaknesses that could be exploited
4. **Impact Analysis**: Assessed potential consequences of successful attacks
5. **Likelihood Evaluation**: Determined probability of threat occurrence
6. **Risk Calculation**: Applied quantitative scoring using Risk = Likelihood × Impact
7. **Risk Prioritization**: Ranked risks based on calculated scores and business criticality

The methodology ensures comprehensive coverage of cybersecurity risks while providing actionable insights for risk treatment decisions.

Risk Assessment Matrix

The following Risk Assessment Matrix reflects the likelihood and impact assessment for Equifax's critical assets following the 2017 data breach incident:

Calculation Method:

- **Product = (L × I)** for each threat
- **Average = ((L × I) + (L × I) + (L × I)) ÷ 3** for overall asset risk score

REF	ASSET	Threat 1	Threat 2	Threat 3	Average or Asset's Risk Score
1	Consumer Credit Database	(5×5) = 25	(4×5) = 20	(3×4) = 12	19.0
2	Web Application Infrastructure	(4×4) = 16	(5×4) = 20	(3×3) = 9	15.0
3	Customer Personal Data Repository	(5×5) = 25	(4×4) = 16	(4×5) = 20	20.3
4	IT Network Systems	(4×4) = 16	(3×3) = 9	(4×4) = 16	13.7
5	Corporate Reputation	(5×5) = 25	(4×5) = 20	(5×4) = 20	21.7

Table 3: Risk Assessment Matrix

Rating Scales:

- **Likelihood:** 1 (Very Low) to 5 (Very High)
- **Impact:** 1 (Minimal) to 5 (Catastrophic)

Top Two At-Risk Assets

Based on the Risk Assessment Matrix, the **top two at-risk assets** for Equifax are:

1. Corporate Reputation (Average Risk Score: 21.7)

Justification: Corporate reputation represents the highest risk to Equifax following the 2017 data breach. The company's reputation is fundamental to its business model as consumers and businesses must trust Equifax with sensitive financial information. The breach has severely damaged this trust, with immediate impacts including:

- **24% stock price decline** in the days following disclosure
- Loss of consumer confidence in credit monitoring services
- Increased regulatory scrutiny and congressional hearings
- Potential long-term revenue loss from reduced market share

The high likelihood of continued reputational damage (5/5) combined with catastrophic business impact (5/5) makes this the most critical risk requiring immediate attention.

2. Customer Personal Data Repository (Average Risk Score: 20.3)

Justification: The customer personal data repository containing PII, Social Security numbers, and financial information remains highly vulnerable following the breach. This asset represents both the target of the original attack and continues to face elevated risk due to:

- **Ongoing threat actor interest** in remaining unpatched systems
- **Regulatory compliance requirements** under GDPR, CCPA, and other privacy laws
- **Legal liability exposure** for inadequate data protection
- **Customer trust dependency** on secure data handling

The repository's vulnerabilities make it susceptible to future attacks (likelihood 5/5), while the impact of additional data compromise would be catastrophic (5/5) for both customers and business operations.

Asset-Based Assessment & Summary

REF	ASSET NAME & DESCRIPTION	TYPE (P/F/S)	THREATS (e.g. data breaches, DDoS attacks, malware)	ADDITIONAL COMMENTS
1	**Consumer Credit Database**: Primary repository containing credit reports, scores, and financial histories for 800+ million consumers	F	• Advanced Persistent Threats • SQL Injection Attacks • Insider Threats	If compromised again, would result in complete business failure, massive legal liability, and permanent loss of operating license. Core business asset requiring maximum protection.
2	**Web Application Infrastructure**: Apache Struts-based applications providing online services and data access portals	P	• Unpatched Vulnerabilities • Web Application Attacks • DDoS Attacks	The original attack vector through CVE-2017-5638. If not properly secured, remains entry point for future attacks. Critical for business operations and customer access.
3	**Customer Personal Data Repository**: Centralized storage of PII including SSNs, addresses, phone numbers, and identification documents	F	• Data Exfiltration • Ransomware Attacks • Unauthorized Acces	Contains the most sensitive customer information. Additional compromise would trigger severe regulatory penalties, class-action lawsuits, and potential criminal charges.
4	**IT Network Systems**: Core networking infrastructure including servers, databases, and	P	• Network Intrusions • Lateral Movement • System Compromises	Provides foundation for all digital operations. Network compromise enables access to all other assets. Essential for business continuity and data integrity.

	communication systems			
5	**Corporate Reputation**: Brand trust, market position, and stakeholder confidence in Equifax's ability to protect sensitive data	S	• Media Coverage • Regulatory Actions • Customer Defection	Already severely damaged by breach disclosure. Further reputation damage could result in business closure, regulatory intervention, or forced acquisition. Recovery requires years of consistent security performance.

Table 4: Risk assessment results summary (asset-based)

Mitigation Strategies

1. For Corporate Reputation (Top Risk Asset)

Strategy 1: Comprehensive Public Transparency Initiative

- Implement regular public reporting on security improvements and incident response capabilities
- Establish independent security oversight board with public reporting requirements
- Create consumer-facing security dashboard showing real-time protection measures
- **Effectiveness**: High - Rebuilds trust through demonstrated commitment to security and accountability

Strategy 2: Enhanced Customer Protection and Compensation

- Expand free credit monitoring services to all affected consumers for extended periods
- Implement comprehensive identity theft insurance and resolution services
- Create dedicated customer support teams for breach-related issues
- **Effectiveness**: Medium - Addresses immediate customer concerns but requires sustained execution

Strategy 3: Regulatory Compliance Excellence Program

- Exceed all regulatory requirements for data protection and breach notification
- Implement continuous compliance monitoring and reporting systems
- Engage proactively with regulators on security improvements
- **Effectiveness**: High - Demonstrates commitment to regulatory requirements and reduces future penalties

3. For Customer Personal Data Repository (Second-Highest Risk Asset)

Strategy 1: Advanced Data Encryption and Tokenization

- Implement end-to-end encryption for all stored PII with regular key rotation
- Deploy tokenization to replace sensitive data with non-sensitive equivalents
- Establish hardware security modules (HSMs) for key management
- **Effectiveness**: Very High - Makes stolen data unusable even if accessed by attackers

Strategy 2: Zero-Trust Security Architecture

- Implement micro-segmentation to isolate data repositories
- Deploy continuous authentication and authorization verification
- Establish strict access controls with principle of least privilege
- **Effectiveness**: High - Prevents lateral movement and limits attack surface

Strategy 3: Advanced Threat Detection and Response

- Deploy AI-powered behavioral analytics to detect unusual data access patterns
- Implement Security Operations Center (SOC) with 24/7 monitoring
- Establish automated incident response playbooks for data access anomalies
- **Effectiveness**: High - Enables rapid detection and response to potential data breaches

Risk Treatment Plan

Risk Category	Treatment Strategy	Implementation	Rationale

Apache Struts Vulnerabilities	Mitigation	• Immediate patching of all systems • Automated vulnerability scanning • Regular security updates schedule	Critical to prevent repeat of original attack vector
Data Breach Recurrence	Mitigation	• Multi-layered security controls • Enhanced monitoring systems • Incident response procedures	Most cost-effective approach to reduce likelihood and impact
Regulatory Penalties	**Avoidance/ Mitigation**	• Proactive compliance program • Legal risk assessment • Regulatory engagement strategy	Avoidance through compliance; mitigation through cooperation
Class Action Lawsuits	Transfer/Mitigation	• Cyber liability insurance • Legal defense preparation • Settlement fund establishment	Transfer financial risk; mitigate through proactive legal strategy
Business Continuity Risks	Mitigation	• Disaster recovery planning • Business continuity testing • Alternative service provisions	Essential for maintaining operations during recovery
Minor Technical Vulnerabilities	Acceptance	• Regular risk assessment • Cost-benefit analysis • Monitoring protocols	Accept low-impact risks where mitigation costs exceed benefits

Priority Implementation:

1. **Immediate (0-30 days)**: Critical system patching, emergency response procedures
2. **Short-term (1-6 months)**: Advanced security controls, compliance framework
3. **Medium-term (6-12 months)**: Comprehensive security architecture, reputation recovery
4. **Long-term (1+ years)**: Culture transformation, industry leadership in cybersecurity

Conclusion & Recommendations

The 2017 Equifax data breach represents one of the most significant cybersecurity failures in corporate history, with far-reaching implications for the company's operations, reputation, and financial stability. This risk assessment has identified critical vulnerabilities and provided a roadmap for recovery and future protection.

Key Findings:

- **Corporate reputation** faces the highest risk, requiring sustained effort to rebuild stakeholder trust
- **Customer personal data repositories** remain vulnerable to sophisticated attacks
- **Web application infrastructure** requires immediate security hardening to prevent repeat incidents
- **Regulatory compliance** demands exceed standard industry practices given the breach's scope

Critical Success Factors:

1. **Leadership Commitment**: Executive-level ownership of cybersecurity transformation
2. **Resource Investment**: Substantial budget allocation for security infrastructure and personnel
3. **Cultural Change**: Organization-wide commitment to security-first mindset
4. **Stakeholder Engagement**: Proactive communication with customers, regulators, and investors
5. **Continuous Improvement**: Regular assessment and enhancement of security measures

Immediate Actions Required:

- Patch all Apache Struts systems and implement comprehensive vulnerability management
- Establish 24/7 Security Operations Center with advanced threat detection capabilities
- Deploy multi-factor authentication across all systems with access to sensitive data
- Implement comprehensive data encryption and access logging
- Create executive-level cybersecurity governance committee

Long-term Strategic Recommendations:

- Transform Equifax into a cybersecurity industry leader through innovation and best practices
- Establish strategic partnerships with cybersecurity firms and research institutions
- Develop proprietary security technologies to differentiate from competitors
- Create industry standards for credit reporting agency data protection
- Build security expertise as a core competency rather than supporting function

The path forward requires unprecedented investment in cybersecurity capabilities, organizational transformation, and sustained commitment to protecting consumer data. Success in these efforts will not only restore Equifax's reputation but position the company as a leader in data protection and cybersecurity excellence.

Conclusion

The 2017 Equifax data breach represents a catastrophic cybersecurity failure that compromised the personal information of 147.9 million consumers and fundamentally altered the company's risk profile across all operational domains. This comprehensive risk assessment has identified corporate reputation and customer personal data repositories as the highest-risk assets, with critical threat levels requiring immediate and sustained remediation efforts. The analysis reveals that Equifax faces an unprecedented combination of technical vulnerabilities, regulatory scrutiny, legal liability, and reputational damage that threatens the organization's long-term viability. Implementation of the recommended mitigation strategies, including advanced encryption, zero-trust architecture, comprehensive compliance programs, and transparent stakeholder communication, is essential for business survival and recovery. The path forward demands substantial financial investment, organizational transformation, and unwavering executive commitment to cybersecurity excellence to restore stakeholder trust and prevent future incidents of similar magnitude. Success in executing this risk treatment plan will not only ensure Equifax's operational continuity but position the company as a leader in data protection practices within the credit reporting industry.

Appendices & Supporting Documentation

References

Berghel, H. (2017). Equifax and the latest round of identity theft roulette. *Computer*, 50(12), 72-76. https://doi.org/10.1109/MC.2017.4451015

Equifax Inc. (2017, September 7). *Equifax announces cybersecurity incident involving consumer information* [Press release]. https://investor.equifax.com/news-and-events/news/2017/09-07-2017-213000628

Federal Bureau of Investigation. (2020, February 10). *Chinese military personnel charged with computer fraud, economic espionage and wire fraud for hacking into credit reporting agency Equifax* [Press release]. U.S. Department of Justice. https://www.justice.gov/opa/pr/chinese-military-personnel-charged-computer-fraud-economic-espionage-and-wire-fraud-hacking

Federal Trade Commission. (2019, July 22). *Equifax to pay $575 million as part of settlement with FTC, CFPB, and states related to 2017 data breach* [Press release]. https://www.ftc.gov/news-events/press-releases/2019/07/equifax-pay-575-million-part-settlement-ftc-cfpb-states-related

International Organization for Standardization. (2013). *ISO/IEC 27001:2013 Information technology — Security techniques — Information security management systems — Requirements*. ISO.

NIST. “Cybersecurity Framework.” *National Institute of Standards and Technology*, 2025, www.nist.gov/cyberframework.

Standards and Technology. (2018). *Framework for improving critical infrastructure cybersecurity* (Version 1.1). U.S. Department of Commerce. https://doi.org/10.6028/NIST.CSWP.04162018

Risk Matrix

Asset/Risk	Likelihood	Impact	Risk Score	Risk Level
Consumer Credit Database - Advanced Persistent Threats	5	5	25	**Critical**
Consumer Credit Database - SQL Injection Attacks	4	5	20	**Critical**
Consumer Credit Database - Insider Threats	3	4	12	**Medium**
Web Application Infrastructure - Unpatched Vulnerabilities	4	4	16	**High**
Web Application Infrastructure - Web Application Attacks	5	4	20	**Critical**
Web Application Infrastructure - DDoS Attacks	3	3	9	**Medium**

Asset/Risk	Likelihood	Impact	Risk Score	Risk Level
Customer Personal Data Repository - Data Exfiltration	5	5	25	**Critical**
Customer Personal Data Repository - Ransomware Attacks	4	4	16	**High**
Customer Personal Data Repository - Unauthorized Access	4	5	20	**Critical**
IT Network Systems - Network Intrusions	4	4	16	**High**
IT Network Systems - Lateral Movement	3	3	9	**Medium**
IT Network Systems - System Compromises	4	4	16	**High**
Corporate Reputation - Media Coverage	5	5	25	**Critical**
Corporate Reputation - Regulatory Actions	4	5	20	**Critical**

Asset/Risk	Likelihood	Impact	Risk Score	Risk Level
Corporate Reputation - Customer Defection	5	4	20	**Critical**

1. Risk Level Legend:

Critical (20-25) **High (15-19)** **Medium (8-14)** **Low (1-7)**

Calculation: *Risk Score = Likelihood × Impact*
Scale: *Likelihood and Impact rated 1-5 (1=Very Low, 2=Low, 3=Moderate, 4=High, 5=Very High)*